
**Sécurité et résilience — Systèmes
de management de la continuité
d'activité — Exigences**

*Security and resilience — Business continuity management systems
— Requirements*





DOCUMENT PROTÉGÉ PAR COPYRIGHT

© ISO 2019

Tous droits réservés. Sauf prescription différente ou nécessité dans le contexte de sa mise en œuvre, aucune partie de cette publication ne peut être reproduite ni utilisée sous quelque forme que ce soit et par aucun procédé, électronique ou mécanique, y compris la photocopie, ou la diffusion sur l'internet ou sur un intranet, sans autorisation écrite préalable. Une autorisation peut être demandée à l'ISO à l'adresse ci-après ou au comité membre de l'ISO dans le pays du demandeur.

ISO copyright office
Case postale 401 • Ch. de Blandonnet 8
CH-1214 Vernier, Genève
Tél.: +41 22 749 01 11
Fax: +41 22 749 09 47
E-mail: copyright@iso.org
Web: www.iso.org

Publié en Suisse

Sommaire

Page

Avant-propos	v
Introduction	vi
1 Domaine d'application	1
2 Références normatives	1
3 Termes et définitions	1
4 Contexte de l'organisme	7
4.1 Compréhension de l'organisme et de son contexte	7
4.2 Compréhension des besoins et attentes des parties intéressées	7
4.2.1 Généralités	7
4.2.2 Exigences réglementaires et juridiques	8
4.3 Détermination du domaine d'application du système de management de la continuité d'activité	8
4.3.1 Généralités	8
4.3.2 Domaine d'application du système de management de la continuité d'activité	8
4.4 Système de management de la continuité d'activité	8
5 Leadership	8
5.1 Leadership et engagement	8
5.2 Politique	9
5.2.1 Établissement de la politique de continuité d'activité	9
5.2.2 Communication de la politique de continuité d'activité	9
5.3 Rôles, responsabilités et autorités	9
6 Planification	10
6.1 Actions face aux risques et opportunités	10
6.1.1 Détermination des risques et opportunités	10
6.1.2 Gestion des risques et opportunités	10
6.2 Objectifs de continuité d'activité et planification pour les atteindre	10
6.2.1 Établissement des objectifs de continuité d'activité	10
6.2.2 Détermination des objectifs de continuité d'activité	10
6.3 Planification des modifications du système de management de la continuité d'activité	11
7 Support	11
7.1 Ressources	11
7.2 Compétences	11
7.3 Sensibilisation (prise de conscience)	11
7.4 Communication	12
7.5 Informations documentées	12
7.5.1 Généralités	12
7.5.2 Création et mise à jour	12
7.5.3 Maîtrise des informations documentées	12
8 Fonctionnement	13
8.1 Planification opérationnelle et maîtrise	13
8.2 Bilan d'impact sur l'activité et appréciation du risque	13
8.2.1 Généralités	13
8.2.2 Bilan d'impact sur l'activité	13
8.2.3 Appréciation du risque	14
8.3 Stratégies et solutions de continuité d'activité	14
8.3.1 Généralités	14
8.3.2 Identification des stratégies et solutions	14
8.3.3 Sélection des stratégies et solutions	15
8.3.4 Exigences de ressources	15
8.3.5 Mise en œuvre des solutions	15
8.4 Plans et procédures de continuité d'activité	15

8.4.1	Généralités	15
8.4.2	Structure de réponse	16
8.4.3	Avertissement et communication	16
8.4.4	Plans de continuité d'activité	17
8.4.5	Rétablissement	18
8.5	Programme d'exercices	18
8.6	Évaluation de la documentation et des capacités de continuité d'activité	18
9	Évaluation de la performance	19
9.1	Surveillance, mesurage, analyse et évaluation	19
9.2	Audit interne	19
9.2.1	Généralités	19
9.2.2	Programme(s) d'audit	19
9.3	Revue de direction	20
9.3.1	Généralités	20
9.3.2	Éléments d'entrée de la revue de direction	20
9.3.3	Éléments de sortie de la revue de direction	20
10	Amélioration	21
10.1	Non-conformité et actions correctives	21
10.2	Amélioration continue	21
	Bibliographie	22

Avant-propos

L'ISO (Organisation internationale de normalisation) est une fédération mondiale d'organismes nationaux de normalisation (comités membres de l'ISO). L'élaboration des Normes internationales est en général confiée aux comités techniques de l'ISO. Chaque comité membre intéressé par une étude a le droit de faire partie du comité technique créé à cet effet. Les organisations internationales, gouvernementales et non gouvernementales, en liaison avec l'ISO participent également aux travaux. L'ISO collabore étroitement avec la Commission électrotechnique internationale (IEC) en ce qui concerne la normalisation électrotechnique.

Les procédures utilisées pour élaborer le présent document et celles destinées à sa mise à jour sont décrites dans les Directives ISO/IEC, Partie 1. Il convient, en particulier, de prendre note des différents critères d'approbation requis pour les différents types de documents ISO. Le présent document a été rédigé conformément aux règles de rédaction données dans les Directives ISO/IEC, Partie 2 (voir www.iso.org/directives).

L'attention est attirée sur le fait que certains des éléments du présent document peuvent faire l'objet de droits de propriété intellectuelle ou de droits analogues. L'ISO ne saurait être tenue pour responsable de ne pas avoir identifié de tels droits de propriété et averti de leur existence. Les détails concernant les références aux droits de propriété intellectuelle ou autres droits analogues identifiés lors de l'élaboration du document sont indiqués dans l'Introduction et/ou dans la liste des déclarations de brevets reçues par l'ISO (voir www.iso.org/brevets).

Les appellations commerciales éventuellement mentionnées dans le présent document sont données pour information, par souci de commodité, à l'intention des utilisateurs et ne sauraient constituer un engagement.

Pour une explication de la nature volontaire des normes, la signification des termes et expressions spécifiques de l'ISO liés à l'évaluation de la conformité, ou pour toute information au sujet de l'adhésion de l'ISO aux principes de l'Organisation mondiale du commerce (OMC) concernant les obstacles techniques au commerce (OTC), voir www.iso.org/avant-propos.

Le présent document a été élaboré par le comité technique ISO/TC 292, *Sécurité et résilience*.

Cette deuxième édition annule et remplace la première édition (ISO 22301:2012), qui a fait l'objet d'une révision technique. Les principales modifications par rapport à l'édition précédente sont les suivantes:

- application des exigences de l'ISO en matière de normes de système de management, qui ont évolué depuis 2012;
- clarification des exigences, sans ajout de nouvelles exigences;
- inclusion dans l'[Article 8](#) de la quasi-totalité des exigences de continuité d'activité en lien avec des disciplines spécifiques;
- restructuration de l'[Article 8](#) pour faciliter la compréhension des exigences essentielles;
- modification d'un certain nombre de termes relatifs à la continuité d'activité en lien avec des disciplines spécifiques pour en améliorer la clarté et refléter les pensées actuelles.

Il convient que l'utilisateur adresse tout retour d'information ou toute question concernant le présent document à l'organisme national de normalisation de son pays. Une liste exhaustive desdits organismes se trouve à l'adresse www.iso.org/fr/members.html.

Introduction

0.1 Généralités

Le présent document spécifie la structure et les exigences relatives à la mise en œuvre et à la maintenance d'un Système de Management de la Continuité d'Activité (SMCA) qui développe une continuité d'activité en fonction de l'importance et du type d'impact que l'organisme peut ou non accepter suite à une perturbation.

Les résultats de la maintenance d'un SMCA sont façonnés par les exigences réglementaires, juridiques, organisationnelles et sectorielles de l'organisme, les produits et services offerts, les processus employés, la taille et la structure de l'organisme et les exigences de ses parties intéressées.

Un SMCA souligne l'importance:

- d'une compréhension des besoins de l'organisme et de la nécessité d'établir des politiques et des objectifs de continuité d'activité;
- du fonctionnement et de la maintenance des processus, capacités et structures de réponse afin d'assurer que l'organisme survivra aux perturbations;
- de surveiller et passer en revue la performance et l'efficacité du SMCA;
- d'une amélioration continue sur la base de mesures qualitatives et quantitatives.

À l'instar de tout autre système de management, un SMCA comprend les composantes suivantes:

- a) une politique;
- b) des personnes compétentes ayant des responsabilités définies;
- c) des processus de management concernant:
 - 1) la politique;
 - 2) la planification;
 - 3) la mise en œuvre et le fonctionnement;
 - 4) l'appréciation des performances;
 - 5) la revue de direction;
 - 6) l'amélioration continue;
- d) des informations documentées venant en support de la maîtrise opérationnelle et permettant de réaliser l'évaluation de la performance.

0.2 Bénéfices d'un système de management de la continuité d'activité

Un SMCA sert à préparer, fournir et maintenir les moyens de maîtrise et les capacités pour gérer l'aptitude globale d'un organisme à continuer à fonctionner pendant les perturbations. En atteignant ce but, l'organisme:

- a) du point de vue de l'activité métier:
 - 1) contribue à ses objectifs stratégiques;
 - 2) acquiert un avantage concurrentiel;
 - 3) protège et renforce sa réputation et sa crédibilité;

- 4) contribue à la résilience de l'organisme;
- b) d'un point de vue financier:
 - 1) réduit l'exposition juridique et financière;
 - 2) diminue les coûts directs et indirects des perturbations;
- c) du point de vue des parties intéressées:
 - 1) protège la vie, la propriété et l'environnement;
 - 2) prend en considération les attentes des parties intéressées;
 - 3) renforce leur confiance en sa capacité de réussite;
- d) du point de vue des processus internes:
 - 1) améliore sa capacité à rester efficace pendant les perturbations;
 - 2) démontre une maîtrise proactive des risques de façon efficace et efficiente;
 - 3) traite les vulnérabilités opérationnelles.

0.3 Cycle PDCA (Plan-Do-Check-Act/Planifier-Déployer-Contrôler-Agir)

Le présent document applique le cycle PDCA [Planifier (établir), Déployer (mettre en œuvre et exécuter), Contrôler (surveiller et réexaminer) et Agir (maintenir et améliorer)] pour assurer la mise en œuvre, la maintenance et l'amélioration continue de l'efficacité du SMCA d'un organisme.

Cela assure un degré de cohérence avec d'autres normes de système de management, telles que l'ISO 9001, l'ISO 14001, l'ISO/IEC 20000-1, l'ISO/IEC 27001 et l'ISO 28000, permettant ainsi une mise en œuvre et un fonctionnement cohérents et intégrés avec les systèmes de management associés.

Conformément au cycle PDCA, les [Articles 4 à 10](#) traitent des éléments suivants.

- L'[Article 4](#) introduit les exigences nécessaires pour établir le contexte du SMCA applicable à l'organisme, ainsi que les besoins, les exigences et le domaine d'application.
- L'[Article 5](#) résume les exigences spécifiques au rôle de la Direction générale dans le SMCA, et la manière dont le leadership communique ses attentes à l'organisme par le biais d'une déclaration de politique.
- L'[Article 6](#) décrit les exigences pour établir des objectifs stratégiques et des principes d'orientation pour le SMCA dans sa globalité.
- L'[Article 7](#) vient à l'appui des opérations du SMCA en lien avec la détermination des compétences et la communication avec les parties intéressées, sur une base récurrente ou en tant que de besoin, tout en documentant, maîtrisant, maintenant et conservant les informations documentées requises.
- L'[Article 8](#) définit les besoins de continuité d'activité, détermine la manière de les traiter et développe les procédures afin de gérer l'organisme durant une perturbation.
- L'[Article 9](#) résume les exigences nécessaires pour mesurer la performance de la continuité d'activité, la conformité du SMCA au présent document et le pilotage de la revue de direction.
- L'[Article 10](#) identifie et intervient sur une non-conformité du SMCA et sur l'amélioration continue par le biais d'une action corrective.

0.4 Contenu du présent document

Le présent document se conforme aux exigences de l'ISO relatives aux normes de systèmes de management. Ces exigences comprennent une structure-cadre, un texte de base identique et des termes

communs avec des définitions clés, élaborés à l'attention des utilisateurs mettant en œuvre plusieurs normes ISO de systèmes de management.

Le présent document ne comporte pas d'exigences spécifiques à d'autres systèmes de management, bien que ses éléments puissent être alignés ou intégrés avec ceux d'autres systèmes de management.

Le présent document contient des exigences qui peuvent être utilisées par un organisme pour mettre en œuvre un SMCA et en apprécier la conformité. Un organisme souhaitant démontrer la conformité au présent document peut le faire:

- en réalisant une auto-évaluation et une auto-déclaration; ou
- en recherchant la confirmation de sa conformité par des parties ayant un intérêt dans l'organisme, telles que les clients; ou
- en recherchant la confirmation de son auto-déclaration par une partie externe à l'organisme; ou
- en recherchant la certification/l'enregistrement de son SMCA par un organisme externe.

Les [Articles 1](#) à [3](#) décrivent le domaine d'application, les références normatives et les termes et définitions qui s'appliquent à l'utilisation du présent document. Les [Articles 4](#) à [10](#) contiennent les exigences à utiliser pour apprécier la conformité au présent document.

Dans le présent document, les formes verbales suivantes sont utilisées:

- a) le verbe «devoir» indique une exigence;
- b) l'expression «il convient de» indique une recommandation;
- c) le verbe «pouvoir» (may) indique une permission;
- d) le verbe «pouvoir» (can) indique une possibilité ou capacité.

Les informations sous forme de «NOTE» sont fournies pour faciliter la compréhension de l'exigence associée ou la clarifier. Les «Notes à l'article» employées à l'[Article 3](#) fournissent des informations supplémentaires qui viennent compléter les données terminologiques et peuvent contenir des dispositions concernant l'usage d'un terme.

Sécurité et résilience — Systèmes de management de la continuité d'activité — Exigences

1 Domaine d'application

Le présent document spécifie les exigences pour mettre en œuvre, maintenir et améliorer un système de management afin de se protéger contre les perturbations, réduire la vraisemblance de leur survenance, s'y préparer, y répondre et se rétablir lorsqu'elles se produisent.

Les exigences spécifiées dans le présent document sont génériques et prévues pour être applicables à tous les organismes, ou à des parties de ceux-ci, indépendamment du type, de la taille et de la nature de l'organisme. Le champ d'application de ces exigences dépend de l'environnement et de la complexité de fonctionnement de l'organisme.

Le présent document est applicable à tous les types et toutes les tailles d'organismes qui:

- a) mettent en œuvre, maintiennent et améliorent un SMCA;
- b) cherchent à assurer la conformité à la politique de continuité d'activité déclarée;
- c) ont besoin d'être aptes à poursuivre la livraison de produits et la fourniture de services à un niveau de capacité acceptable et préalablement défini durant une perturbation;
- d) cherchent à améliorer leur résilience à travers l'application efficace du SMCA.

Le présent document peut être utilisé pour apprécier l'aptitude d'un organisme à satisfaire ses propres besoins et obligations en matière de continuité d'activité.

2 Références normatives

Les documents suivants sont cités dans le texte de sorte qu'ils constituent, pour tout ou partie de leur contenu, des exigences du présent document. Pour les références datées, seule l'édition citée s'applique. Pour les références non datées, la dernière édition du document de référence s'applique (y compris les éventuels amendements).

ISO 22300, *Sécurité et résilience — Vocabulaire*

3 Termes et définitions

Pour les besoins du présent document, les termes et les définitions de l'ISO 22300 ainsi que les suivants s'appliquent.

L'ISO et l'IEC tiennent à jour des bases de données terminologiques destinées à être utilisées en normalisation, consultables aux adresses suivantes:

- ISO Online browsing platform: disponible à l'adresse <https://www.iso.org/obp>
- IEC Electropedia: disponible à l'adresse <http://www.electropedia.org/>

NOTE Les termes et définitions ci-dessous remplacent ceux donnés dans l'ISO 22300:2018.

3.1 activité

ensemble d'une ou plusieurs tâches ayant une finalité définie

[SOURCE: ISO 22300:2018, 3.1, modifiée — La définition a été remplacée et l'exemple a été supprimé.]

3.2

audit

processus (3.26) méthodique, indépendant et documenté en vue d'obtenir des preuves d'audit et de les évaluer de manière objective pour déterminer dans quelle mesure les critères d'audit sont satisfaits

Note 1 à l'article: Un audit peut être interne (audit de première partie), externe (audit de seconde ou de tierce partie) ou combiné (combinant deux disciplines ou plus).

Note 2 à l'article: Un audit interne est réalisé par l'*organisme* (3.21) lui-même ou par une partie externe pour le compte de celui-ci.

Note 3 à l'article: Les termes «preuves d'audit» et «critères d'audit» sont définis dans l'ISO 19011.

Note 4 à l'article: Les éléments fondamentaux d'un audit comprennent la détermination de la *conformité* (3.7) d'un objet selon une procédure réalisée par du personnel n'étant pas responsable de l'objet audité.

Note 5 à l'article: Un audit interne peut être réalisé pour une revue de direction et d'autres besoins internes et peut servir de base à la déclaration de conformité de l'organisme. L'indépendance peut être démontrée par l'absence de responsabilité vis-à-vis de l'*activité* (3.1) à auditer. Les audits externes comprennent les audits de seconde et de tierce partie. Les audits de seconde partie sont réalisés par des parties ayant un intérêt à l'égard de l'organisme, comme les clients, ou d'autres personnes agissant en leur nom. Les audits de tierce partie sont réalisés par des organismes d'audit externes et indépendants tels que ceux qui octroient la certification/l'enregistrement de conformité ou des organismes publics.

Note 6 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO. La définition initiale a été modifiée par l'ajout des Notes 4 et 5 à l'article.

3.3

continuité d'activité

capacité d'un *organisme* (3.21) à poursuivre la livraison de *produits* et la fourniture de *services* (3.27) dans des délais acceptables à une capacité prédéfinie durant une *perturbation* (3.10)

[SOURCE: ISO 22300:2018, 3.24, modifiée — La définition a été remplacée.]

3.4

plan de continuité d'activité

informations documentées (3.11) servant de guide à un *organisme* (3.21) pour répondre à une *perturbation* (3.10) et reprendre, rétablir et restaurer la livraison de *produits* et la fourniture de *services* (3.27) en cohérence avec ses *objectifs* (3.20) de *continuité d'activité* (3.3)

[SOURCE: ISO 22300:2018, 3.27, modifiée — La définition a été remplacée et la Note 1 à l'article a été supprimée.]

3.5

bilan d'impact sur l'activité

processus (3.26) d'analyse de l'*impact* (3.13) dans le temps d'une *perturbation* (3.10) sur l'*organisme* (3.21)

Note 1 à l'article: Le résultat est un inventaire des *exigences* (3.28) de *continuité d'activité* (3.3) et leur justification.

[SOURCE: ISO 22300:2018, 3.29, modifiée — La définition a été remplacée et la Note 1 à l'article a été ajoutée.]

3.6

compétence

aptitude à mettre en pratique des connaissances et un savoir-faire pour obtenir les résultats escomptés

Note 1 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO.

3.7**conformité**

satisfaction d'une *exigence* (3.28)

Note 1 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO.

3.8**amélioration continue**

activité (3.1) récurrente permettant d'améliorer les *performances* (3.23)

Note 1 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO.

3.9**action corrective**

action visant à éliminer la ou les cause(s) d'une *non-conformité* (3.19) et à éviter sa réapparition

Note 1 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO.

3.10**perturbation**

incident (3.14), anticipé ou non, qui entraîne un écart négatif non planifié par rapport à la livraison de *produits* et à la fourniture de *services* (3.27) prévues selon les *objectifs* (3.20) d'un *organisme* (3.21)

[SOURCE: ISO 22300:2018, 3.70, modifiée — La définition a été remplacée.]

3.11**information documentée**

information devant être maîtrisée et tenue à jour par un *organisme* (3.21) ainsi que le support sur lequel elle figure

Note 1 à l'article: Les informations documentées peuvent se présenter sous n'importe quel format et sur tous supports et peuvent provenir de toute source.

Note 2 à l'article: Les informations documentées peuvent se rapporter:

- au *système de management* (3.16), y compris aux *processus* (3.26) connexes;
- aux informations créées en vue du fonctionnement de l'organisme (documentation);
- aux preuves des résultats obtenus (enregistrements).

Note 3 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO.

3.12**efficacité**

niveau de réalisation des *activités* (3.1) planifiées et d'obtention des résultats escomptés

Note 1 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO.

3.13**impact**

résultat d'une *perturbation* (3.10) affectant les *objectifs* (3.20)

[SOURCE: ISO 22300:2018, 3.107, modifiée — La définition a été remplacée.]

3.14 **incident**

événement qui peut être, ou conduire à, une *perturbation* (3.10), une perte, une urgence ou une crise

[SOURCE: ISO 22300:2018, 3.111, modifiée — La définition a été remplacée.]

3.15 **partie intéressée (terme recommandé)**

partie prenante (terme admis)

personne ou *organisme* (3.21) qui peut affecter une décision ou une *activité* (3.1), ou être affecté ou s'estimer affecté par une décision ou une *activité* (3.1)

EXEMPLE Clients, propriétaires, personnel, prestataires, établissements financiers, autorités réglementaires, syndicats, partenaires ou société pouvant inclure des concurrents ou des groupes de pression d'opposition.

Note 1 à l'article: Un décideur peut être une partie intéressée.

Note 2 à l'article: Les communautés impactées et les populations locales sont considérées comme des parties intéressées.

Note 3 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO. La définition initiale a été modifiée par l'ajout d'un exemple et des Notes 1 et 2 à l'article.

3.16 **système de management**

ensemble d'éléments corrélés ou en interaction d'un *organisme* (3.21), utilisés pour établir des *politiques* (3.24), des *objectifs* (3.20) et des *processus* (3.26) de façon à atteindre ces objectifs

Note 1 à l'article: Un système de management peut traiter d'une seule ou de plusieurs disciplines.

Note 2 à l'article: Les éléments du système comprennent la structure, les rôles et responsabilités, la planification et le fonctionnement de l'organisme.

Note 3 à l'article: Le domaine d'application d'un système de management peut comprendre l'ensemble de l'organisme, des fonctions spécifiques et identifiées de l'organisme, des sections spécifiques et identifiées de l'organisme, ou une ou plusieurs fonctions dans un groupe d'organismes.

Note 4 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO.

3.17 **mesurage**

processus (3.26) visant à déterminer une valeur

Note 1 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO.

3.18 **surveillance**

détermination de l'état d'un système, d'un *processus* (3.26) ou d'une *activité* (3.1)

Note 1 à l'article: Pour déterminer l'état, il peut être nécessaire de vérifier, superviser ou observer de manière critique.

Note 2 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO.

3.19**non-conformité**

non-satisfaction d'une *exigence* (3.28)

Note 1 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO.

3.20**objectif**

résultat à atteindre

Note 1 à l'article: Un objectif peut être stratégique, tactique ou opérationnel.

Note 2 à l'article: Les objectifs peuvent se rapporter à différentes disciplines (par exemple, buts financiers, de santé et de sécurité, ou environnementaux) et peuvent concerner différents niveaux (par exemple, au niveau stratégique, à l'échelle de l'organisme, au niveau d'un projet, d'un produit et d'un *processus*) (3.26)].

Note 3 à l'article: Un objectif peut être exprimé autrement, par exemple soit comme un résultat escompté, une mission, un critère opérationnel, soit comme un objectif de *continuité d'activité* (3.3), ou encore à l'aide d'autres mots ayant un sens similaire (par exemple finalité, but, cible).

Note 4 à l'article: Dans le contexte des *systèmes de management de la continuité d'activité* (3.16), les objectifs de continuité d'activité sont fixés par l'*organisme* (3.21), en cohérence avec sa *politique* (3.24) de continuité d'activité, en vue d'atteindre des résultats spécifiques.

Note 5 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO.

3.21**organisme****organisation (Belgique, Canada)**

personne ou groupe de personnes ayant ses propres fonctions, avec des responsabilités, des autorités et des relations lui permettant d'atteindre ses *objectifs* (3.20)

Note 1 à l'article: Le concept d'organisme englobe sans s'y limiter, les travailleurs indépendants, les compagnies, les sociétés, les firmes, les entreprises, les administrations, les partenariats, les organisations caritatives ou les institutions, ou bien une partie ou une combinaison des entités précédentes, à responsabilité limitée ou ayant un autre statut, de droit public ou privé.

Note 2 à l'article: Pour les organismes ayant plusieurs unités d'exploitation, une seule unité d'exploitation peut être définie en tant qu'organisme.

Note 3 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO. La définition initiale a été modifiée par l'ajout de la Note 2 à l'article.

3.22**externaliser**

passer un accord selon lequel un *organisme* (3.21) externe assure une partie de la fonction ou met en œuvre une partie du *processus* (3.26) d'un organisme

Note 1 à l'article: L'organisme externe est en-dehors du domaine d'application du *système de management* (3.16), bien que la fonction ou le processus externalisé en fasse partie intégrante.

Note 2 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO.

3.23**performance**

résultat mesurable

Note 1 à l'article: La performance peut être liée à des constats quantitatifs ou qualitatifs.

Note 2 à l'article: La performance peut se rapporter au management des *activités* (3.1), des *processus* (3.26), des produits (y compris les services), des systèmes ou des *organismes* (3.21).

Note 3 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO.

3.24

politique

intentions et orientations d'un *organisme* (3.21), telles qu'elles sont officiellement formulées par sa *Direction générale* (3.31)

Note 1 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO.

3.25

activité prioritaire

activité (3.1) à laquelle l'urgence est donnée afin d'éviter des *impacts* (3.13) inacceptables sur l'activité durant une *perturbation* (3.10)

[SOURCE: ISO 22300:2018, 3.176, modifiée — La définition a été remplacée et la Note 1 à l'article a été supprimée.]

3.26

processus

ensemble d'*activités* (3.1) corrélées ou interactives qui transforme des éléments d'entrée en éléments de sortie

Note 1 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO.

3.27

produit et service

élément de sortie ou résultat fourni par un *organisme* (3.21) au bénéfice des *parties intéressées* (3.15)

EXEMPLE Articles manufacturés, assurance automobile et soins infirmiers communautaires.

[SOURCE: ISO 22300:2018, 3.181, modifiée — Le terme «produit et service» a remplacé «produit ou service» et la définition a été remplacée.]

3.28

exigence

besoin ou attente qui est formulé, généralement implicite ou obligatoire

Note 1 à l'article: «Généralement implicite» signifie qu'il est habituel ou courant, pour l'*organisme* (3.21) et les *parties intéressées* (3.15), que le besoin ou l'attente en question soit implicite.

Note 2 à l'article: Une exigence spécifiée est une exigence formulée, par exemple dans une *information documentée* (3.11).

Note 3 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO.

3.29

ressource

ensemble des biens (y compris l'usine et ses équipements), du personnel, des compétences, de la technologie, des locaux, et des fournitures et informations (qu'elles soient électroniques ou non) dont doit disposer un *organisme* (3.21), au moment requis, pour fonctionner et atteindre son *objectif* (3.20)

[SOURCE: ISO 22300:2018, 3.193, modifiée — La définition a été remplacée.]

3.30**risque**

effet de l'incertitude sur les *objectifs* (3.20)

Note 1 à l'article: Un effet est un écart par rapport à une attente - positif ou négatif.

Note 2 à l'article: L'incertitude est l'état, même partiel, de défaut d'information concernant la compréhension ou la connaissance d'un événement, de ses conséquences ou de sa vraisemblance.

Note 3 à l'article: Un risque est souvent caractérisé par référence à des «événements» potentiels (tels que définis dans le Guide ISO 73) et à des «conséquences» potentielles (telles que définies dans le Guide ISO 73), ou par référence à une combinaison des deux.

Note 4 à l'article: Un risque est souvent exprimé en termes de combinaison des conséquences d'un événement (y compris des changements de circonstances) et de la «vraisemblance» de son occurrence (telle que définie dans le Guide ISO 73).

Note 5 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO. La définition a été modifiée par l'ajout de «sur les objectifs» afin d'assurer la cohérence avec ISO 31000.

3.31**Direction générale****Haute direction (Canada)**

personne ou groupe de personnes qui oriente et dirige un *organisme* (3.21) au plus haut niveau

Note 1 à l'article: La Direction générale a le pouvoir de déléguer son autorité et de fournir des *ressources* (3.29) au sein de l'organisme.

Note 2 à l'article: Si le domaine d'application du *système de management* (3.16) ne couvre qu'une partie de l'organisme, alors la Direction générale concerne ceux qui orientent et dirigent cette partie de l'organisme.

Note 3 à l'article: Cela constitue l'un des termes communs et l'une des définitions essentielles de la structure-cadre (HLS) des normes de système de management ISO.

4 Contexte de l'organisme**4.1 Compréhension de l'organisme et de son contexte**

L'organisme doit déterminer les questions externes et internes pertinentes par rapport à sa finalité, et qui affectent sa capacité à atteindre le ou les résultats attendus de son SMCA.

NOTE Ces questions seront influencées par les objectifs globaux de l'organisme, ses produits et services et le niveau et le type de risque qu'il peut prendre ou non.

4.2 Compréhension des besoins et attentes des parties intéressées**4.2.1 Généralités**

Lors de l'établissement de son SMCA, l'organisme doit déterminer:

- a) les parties intéressées qui sont pertinentes pour le SMCA;
- b) les exigences de ces parties intéressées.

4.2.2 Exigences réglementaires et juridiques

L'organisme doit:

- a) mettre en œuvre et maintenir un processus lui permettant d'identifier les exigences réglementaires et juridiques concernant la continuité de ses produits et services, activités et ressources, d'y avoir accès et de les évaluer;
- b) s'assurer que les exigences réglementaires et juridiques ou autres, applicables, sont prises en compte lorsqu'il met en œuvre et maintient son SMCA;
- c) documenter ces informations et les tenir à jour.

4.3 Détermination du domaine d'application du système de management de la continuité d'activité

4.3.1 Généralités

Pour établir le domaine d'application du SMCA, l'organisme doit en déterminer les limites et l'applicabilité.

- a) Lorsqu'il établit ce domaine d'application, il doit prendre en considération:
- b) les questions externes et internes auxquelles il est fait référence en [4.1](#);
- c) les exigences auxquelles il est fait référence en [4.2](#);
- d) sa mission, ses buts et ses obligations internes et externes.

Le domaine d'application doit être disponible sous forme d'information documentée.

4.3.2 Domaine d'application du système de management de la continuité d'activité

L'organisme doit:

- a) établir les parties de l'organisme à inclure dans le SMCA, en prenant en compte leur(s) emplacement(s), taille, nature et complexité;
- b) identifier les produits et services à inclure dans le SMCA.

Lors de la définition du domaine d'application, l'organisme doit documenter et expliquer les exclusions. Elles ne doivent pas affecter l'aptitude et la responsabilité de l'organisme à assurer la continuité de l'activité, tel que déterminé par le bilan d'impact sur l'activité ou l'appréciation du risque et par les exigences réglementaires ou juridiques applicables.

4.4 Système de management de la continuité d'activité

L'organisme doit établir, mettre en œuvre, maintenir et continuellement améliorer un SMCA, incluant les processus nécessaires et leurs interactions, en accord avec les exigences du présent document.

5 Leadership

5.1 Leadership et engagement

La Direction générale doit démontrer son leadership et son engagement en faveur du SMCA en:

- a) s'assurant que la politique et les objectifs de continuité d'activité sont établis et qu'ils sont compatibles avec l'orientation stratégique de l'organisme;
- b) s'assurant que les exigences du SMCA sont intégrées aux processus métier de l'organisme;

- c) s'assurant que les ressources nécessaires pour le SMCA sont disponibles;
- d) communiquant sur l'importance d'une continuité d'activité efficace et de se conformer aux exigences du SMCA;
- e) s'assurant que le SMCA atteint le ou les résultats escomptés;
- f) orientant et soutenant les personnes pour qu'elles contribuent à l'efficacité du SMCA;
- g) promouvant l'amélioration continue;
- h) aidant les autres managers concernés à démontrer leur leadership et leur engagement dès lors que cela s'applique à leurs domaines de responsabilité.

NOTE Dans le présent document, il est possible d'interpréter le terme «activité» de façon large, c'est-à-dire comme se référant aux activités qui sont au cœur des finalités de l'existence de l'organisme.

5.2 Politique

5.2.1 Établissement de la politique de continuité d'activité

La Direction générale doit établir une politique de continuité d'activité qui:

- a) est appropriée à la mission de l'organisme;
- b) fournit un cadre pour l'établissement d'objectifs de continuité d'activité;
- c) inclut l'engagement de satisfaire aux exigences applicables;
- d) inclut l'engagement d'amélioration continue du SMCA.

5.2.2 Communication de la politique de continuité d'activité

La politique de continuité d'activité doit:

- a) être disponible sous forme d'information documentée;
- b) être communiquée au sein de l'organisme;
- c) être à la disposition des parties intéressées, comme approprié.

5.3 Rôles, responsabilités et autorités

La Direction générale doit s'assurer que les responsabilités et autorités pour les rôles pertinents sont attribuées et communiquées au sein de l'organisme.

La Direction générale doit désigner qui a la responsabilité et l'autorité de:

- a) s'assurer que le SMCA est conforme aux exigences du présent document;
- b) rendre compte à la Direction générale de la performance du SMCA.

6 Planification

6.1 Actions face aux risques et opportunités

6.1.1 Détermination des risques et opportunités

Lorsqu'il conçoit son SMCA, l'organisme doit prendre en considération les questions auxquelles il est fait référence en [4.1](#) et les exigences auxquelles il est fait référence en [4.2](#) et déterminer les risques et opportunités auxquels il faut faire face pour:

- a) fournir l'assurance que le SMCA peut atteindre le ou les résultats escomptés;
- b) empêcher ou limiter les effets indésirables; et
- c) obtenir une démarche d'amélioration continue.

6.1.2 Gestion des risques et opportunités

L'organisme doit planifier:

- a) les actions à mener face aux risques et opportunités;
- b) la manière:
 - 1) d'intégrer et de mettre en œuvre ces actions au sein des processus du SMCA (voir [8.1](#)); et
 - 2) d'évaluer l'efficacité de ces actions (voir [9.1](#)).

NOTE Les risques et opportunités se rapportent à l'efficacité du système de management. Les risques liés à une perturbation de l'activité relèvent du [8.2](#).

6.2 Objectifs de continuité d'activité et planification pour les atteindre

6.2.1 Établissement des objectifs de continuité d'activité

L'organisme doit établir les objectifs de continuité d'activité aux fonctions et niveaux pertinents.

Les objectifs de continuité d'activité doivent:

- a) être cohérents avec la politique de continuité d'activité;
- b) être mesurables (si possible);
- c) prendre en compte les exigences applicables (voir [4.1](#) et [4.2](#));
- d) être surveillés;
- e) être communiqués;
- f) être mis à jour comme approprié.

L'organisme doit conserver des informations documentées sur les objectifs de continuité d'activité.

6.2.2 Détermination des objectifs de continuité d'activité

Lorsque l'organisme planifie la façon d'atteindre ses objectifs de continuité d'activité, l'organisme doit déterminer:

- a) ce qui sera fait;
- b) quelles ressources seront requises;

- c) qui sera responsable;
- d) à quelle échéance;
- e) comment les résultats seront évalués.

6.3 Planification des modifications du système de management de la continuité d'activité

Lorsque l'organisme détermine le besoin d'apporter des modifications au SMCA, y compris celles identifiées à l'[Article 10](#), les modifications doivent être réalisées de façon planifiée.

L'organisme doit prendre en considération:

- a) l'objet des modifications et leurs conséquences potentielles;
- b) l'intégrité du SMCA;
- c) la disponibilité des ressources;
- d) l'attribution ou la réattribution des responsabilités et autorités.

7 Support

7.1 Ressources

L'organisme doit déterminer et fournir les ressources nécessaires à l'établissement, la mise en œuvre, la maintenance et l'amélioration continue du SMCA.

7.2 Compétences

L'organisme doit:

- a) déterminer les compétences nécessaires de la ou des personnes effectuant, sous son contrôle, un travail qui affecte ses performances de continuité d'activité;
- b) s'assurer que ces personnes sont compétentes sur la base d'une formation initiale, d'une formation professionnelle ou d'une expérience appropriée;
- c) le cas échéant, mener des actions pour acquérir les compétences nécessaires et évaluer l'efficacité des actions entreprises;
- d) conserver des informations documentées appropriées comme preuves de ces compétences.

NOTE Les actions envisageables peuvent par exemple inclure la formation, l'encadrement ou la réaffectation du personnel actuellement en activité ou le recrutement, direct ou en sous-traitance, de personnes compétentes.

7.3 Sensibilisation (prise de conscience)

Les personnes effectuant un travail sous le contrôle de l'organisme doivent avoir conscience:

- a) de la politique de continuité d'activité;
- b) de leur contribution à l'efficacité du SMCA, y compris les bénéfices d'une amélioration des performances de la continuité d'activité;
- c) des implications de la non-conformité aux exigences du SMCA;
- d) de leurs propres rôle et responsabilités, durant et après des perturbations.

7.4 Communication

L'organisme doit déterminer les éléments de communication interne et externe pertinents pour le SMCA, et notamment:

- a) sur quoi communiquer;
- b) quand communiquer;
- c) avec qui communiquer;
- d) comment communiquer;
- e) qui communiquera.

7.5 Informations documentées

7.5.1 Généralités

Le SMCA de l'organisme doit inclure:

- a) les informations documentées exigées par le présent document;
- b) les informations documentées que l'organisme juge nécessaires à l'efficacité du SMCA.

NOTE L'étendue des informations documentées dans le cadre d'un SMCA peut différer selon l'organisme en fonction de:

- la taille de l'organisme, ses domaines d'activité, ses processus, produits et services, et ses ressources;
- la complexité des processus et de leurs interactions;
- les compétences des personnes.

7.5.2 Création et mise à jour

Quand il crée et met à jour ses informations documentées, l'organisme doit s'assurer que sont appropriés:

- a) l'identification et la description (par exemple titre, date, auteur, numéro de référence);
- b) le format (par exemple langue, version logicielle, graphiques) et le support (par exemple papier, électronique);
- c) la revue et l'approbation du caractère adapté et adéquat des informations.

7.5.3 Maîtrise des informations documentées

7.5.3.1 Les informations documentées exigées par le SMCA et par le présent document doivent être maîtrisées pour s'assurer:

- a) qu'elles sont disponibles et propres à être utilisées, où et quand c'est nécessaire;
- b) qu'elles sont convenablement protégées (par exemple contre la perte de confidentialité, l'utilisation inappropriée ou la perte d'intégrité).

7.5.3.2 Pour maîtriser les informations documentées, l'organisme doit s'occuper des activités suivantes, quand elles lui sont applicables:

- a) distribution, accès, récupération et utilisation;

- b) stockage et préservation, y compris préservation de la lisibilité;
- c) maîtrise des modifications (par exemple maîtrise des versions);
- d) conservation et élimination des informations.

Les informations documentées d'origine externe que l'organisme juge nécessaires à la planification et au fonctionnement du SMCA doivent être identifiées, le cas échéant, et maîtrisées.

NOTE L'accès peut impliquer une décision concernant l'autorisation de consulter les informations documentées uniquement, ou l'autorisation et l'autorité de consulter et modifier les informations documentées.

8 Fonctionnement

8.1 Planification opérationnelle et maîtrise

L'organisme doit planifier, mettre en œuvre et maîtriser les processus nécessaires pour satisfaire aux exigences et réaliser les actions déterminées en [6.1](#), en:

- a) établissant les critères pour ces processus;
- b) mettant en œuvre la maîtrise de ces processus en accord avec ces critères;
- c) conservant des informations documentées pour être en mesure de montrer que les processus ont été menés comme prévu.

L'organisme doit maîtriser les modifications prévues et passer en revue les conséquences des modifications non intentionnelles, si nécessaire en menant des actions pour limiter tout effet adverse.

L'organisme doit s'assurer que les processus externalisés et la chaîne d'approvisionnement sont maîtrisés.

8.2 Bilan d'impact sur l'activité et appréciation du risque

8.2.1 Généralités

L'organisme doit:

- a) mettre en œuvre et maintenir des processus systématiques pour le bilan d'impact sur l'activité et l'appréciation des risques de perturbation;
- b) passer en revue le bilan d'impact sur l'activité et l'appréciation du risque à des intervalles planifiés et lorsque des changements significatifs interviennent au sein de l'organisme ou dans le contexte dans lequel il opère.

NOTE L'organisme détermine l'ordre dans lequel le bilan d'impact sur l'activité et l'appréciation du risque sont effectués.

8.2.2 Bilan d'impact sur l'activité

L'organisme doit utiliser le processus de bilan d'impact sur l'activité afin de déterminer les priorités et les exigences de continuité d'activité. Le processus doit:

- a) définir les types d'impacts et les critères pertinents pour le contexte de l'organisme;
- b) identifier les activités qui supportent la livraison des produits et la fourniture des services;
- c) utiliser les types d'impacts et les critères pour apprécier les impacts dans le temps découlant de la perturbation de ces activités;

- d) identifier la durée au-delà de laquelle les impacts d'une non-reprise de ces activités deviendraient inacceptables pour l'organisme;

NOTE 1 Ce délai peut être appelé «durée maximale tolérable de perturbation (DMTP)».

- e) déterminer les délais par ordre de priorité à l'intérieur de la durée identifiée en d) pour reprendre les activités perturbées avec une capacité minimale acceptable spécifiée;

NOTE 2 Ce délai peut être désigné comme «objectif de délai de rétablissement (RTO)».

- f) utiliser ce bilan pour identifier les activités prioritaires;
- g) déterminer quelles ressources sont nécessaires pour soutenir les activités prioritaires;
- h) déterminer les dépendances, y compris les partenaires et fournisseurs, et interdépendances des activités prioritaires.

8.2.3 Appréciation du risque

L'organisme doit mettre en œuvre et maintenir un processus d'appréciation du risque.

NOTE 1 Le processus d'appréciation du risque est couvert par l'ISO 31000.

L'organisme doit:

- a) identifier les risques de perturbation pour les activités prioritaires de l'organisme, ainsi que pour les ressources requises;
- b) analyser et évaluer les risques identifiés;
- c) déterminer quels risques exigent un traitement.

NOTE 2 Les risques dans ce paragraphe se rapportent à la perturbation des activités métier. Les risques et opportunités liés à l'efficacité du système de management relèvent du [6.1](#).

8.3 Stratégies et solutions de continuité d'activité

8.3.1 Généralités

En se basant sur les éléments de sortie du bilan d'impact sur l'activité et de l'appréciation du risque, l'organisme doit identifier et sélectionner des stratégies de continuité d'activité qui prennent en compte des options pour avant, pendant et après une perturbation. Les stratégies de continuité d'activité doivent comprendre une ou plusieurs solutions.

8.3.2 Identification des stratégies et solutions

L'identification doit prendre en considération dans quelle mesure les stratégies et solutions:

- a) satisfont aux exigences pour poursuivre et rétablir les activités prioritaires dans les délais identifiés et au niveau de capacité convenu;
- b) protègent les activités prioritaires de l'organisme;
- c) réduisent la vraisemblance des perturbations;
- d) raccourcissent la période de perturbation;
- e) limitent l'impact de la perturbation sur les produits et services de l'organisme;
- f) assurent la disponibilité des ressources adéquates.

8.3.3 Sélection des stratégies et solutions

La sélection doit prendre en considération dans quelle mesure les stratégies et solutions:

- a) satisfont aux exigences pour poursuivre et rétablir les activités prioritaires dans les délais identifiés et au niveau de capacité convenu;
- b) prennent en compte la quantité et le type de risque que l'organisme peut prendre ou non;
- c) prennent en compte les coûts et bénéfices associés.

8.3.4 Exigences de ressources

L'organisme doit déterminer les exigences de ressources pour mettre en œuvre les solutions de continuité d'activité sélectionnées. Les types de ressources considérés doivent comprendre, sans toutefois s'y limiter:

- a) les personnes;
- b) les informations et les données;
- c) l'infrastructure physique telle que les bâtiments, les lieux de travail ou d'autres installations et les utilités associées;
- d) les équipements et les consommables;
- e) les systèmes de technologies de l'information et de la communication (TIC);
- f) le transport et la logistique;
- g) le financement;
- h) les partenaires et fournisseurs.

8.3.5 Mise en œuvre des solutions

L'organisme doit mettre en œuvre et maintenir les solutions de continuité d'activité sélectionnées afin qu'elles puissent être activées quand c'est nécessaire.

8.4 Plans et procédures de continuité d'activité

8.4.1 Généralités

L'organisme doit mettre en œuvre et maintenir une structure de réponse qui permettra d'avertir les parties intéressées pertinentes et de communiquer avec elles en temps opportun. Il doit fournir des plans et procédures pour gérer l'organisme durant une perturbation. Les plans et procédures doivent être utilisés quand c'est nécessaire pour activer les solutions de continuité d'activité.

NOTE Il existe différents types de procédures qui constituent les plans de continuité d'activité.

L'organisme doit identifier et documenter les plans et procédures de continuité d'activité en se basant sur les éléments de sortie des stratégies et solutions retenues.

Les procédures doivent:

- a) être précises concernant les mesures immédiates devant être prises durant une perturbation;
- b) être souples pour répondre aux changements de conditions internes et externes d'une perturbation;
- c) se concentrer sur l'impact d'incidents menant potentiellement à une perturbation;
- d) être efficaces pour réduire l'impact au minimum par la mise en œuvre de solutions appropriées;

- e) attribuer des rôles et responsabilités pour les tâches qu'elles présentent.

8.4.2 Structure de réponse

8.4.2.1 L'organisme doit mettre en œuvre et maintenir une structure identifiant une ou plusieurs équipes chargées de répondre aux perturbations.

8.4.2.2 Les rôles et responsabilités de chaque équipe et les relations entre les équipes doivent être clairement établis.

8.4.2.3 Les équipes doivent être collectivement compétentes pour:

- a) apprécier la nature et l'étendue d'une perturbation ainsi que son impact potentiel;
- b) apprécier l'impact par rapport aux seuils prédéfinis justifiant le lancement initial d'une réponse formelle;
- c) activer une réponse appropriée pour la continuité d'activité;
- d) planifier les actions à entreprendre;
- e) établir des priorités (en considérant la sécurité de la vie des personnes comme la première priorité);
- f) surveiller les effets de la perturbation et la réponse de l'organisme;
- g) activer les solutions de continuité d'activité;
- h) communiquer avec les parties intéressées pertinentes, les autorités et les médias.

8.4.2.4 Chaque équipe doit avoir:

- a) un personnel identifié et ses suppléants, avec la responsabilité, l'autorité et la compétence nécessaires pour exercer le rôle qui leur est attribué;
- b) des procédures documentées afin de guider ses actions (voir [8.4.4](#)), y compris celles destinées à l'activation, au fonctionnement, à la coordination et à la communication de la réponse.

8.4.3 Avertissement et communication

8.4.3.1 L'organisme doit documenter et maintenir des procédures pour:

- a) communiquer en interne et en externe avec les parties intéressées pertinentes, y compris quoi, quand, avec qui et comment communiquer;

NOTE L'organisme peut documenter et maintenir des procédures concernant la manière et les circonstances dans lesquelles l'organisme communique avec les employés et les personnes à contacter en cas d'urgence.

- b) gérer la réception, la documentation et la réponse aux communications provenant des parties intéressées, y compris un système de conseil national ou régional sur les risques ou un système équivalent;
- c) assurer la disponibilité des moyens de communication durant une perturbation;
- d) faciliter une communication structurée avec les services d'urgence;
- e) fournir les détails de la réponse de l'organisme aux médias à la suite d'un incident, y compris une stratégie de communications;
- f) effectuer l'enregistrement des détails de la perturbation, des actions réalisées et des décisions prises.

8.4.3.2 Le cas échéant, les éléments suivants doivent également être considérés et mis en œuvre:

- a) alerter les parties intéressées potentiellement impactées par une perturbation réelle ou imminente;
- b) assurer une coordination et une communication appropriées entre de multiples organismes participant à la réponse.

Les procédures d'avertissement et de communication doivent faire l'objet d'exercices dans le cadre du programme d'exercice de l'organisme décrit en [8.5](#).

8.4.4 Plans de continuité d'activité

8.4.4.1 L'organisme doit documenter et maintenir ses plans et procédures de continuité d'activité. Les plans de continuité d'activité doivent fournir des recommandations et des informations qui aideront les équipes à répondre à une perturbation et aideront l'organisme à répondre et à se rétablir.

8.4.4.2 Les plans de continuité d'activité doivent globalement contenir:

- a) les détails des actions que les équipes accompliront afin de:
 - 1) continuer ou rétablir les activités prioritaires dans des délais prédéterminés;
 - 2) surveiller l'impact de la perturbation et la réponse de l'organisme à celle-ci;
- b) la référence au(x) seuil(s) prédéfini(s) et au processus visant à activer la réponse;
- c) les procédures permettant la livraison des produits et la fourniture des services au niveau de capacité convenu;
- d) les détails permettant de gérer les conséquences immédiates d'une perturbation en tenant dûment compte:
 - 1) du bien-être des individus;
 - 2) de la prévention d'une perte ou indisponibilité supplémentaire d'activités prioritaires;
 - 3) de l'impact sur l'environnement.

8.4.4.3 Chaque plan doit inclure:

- a) le but, le domaine d'application et les objectifs;
- b) les rôles et les responsabilités de l'équipe qui mettra en œuvre le plan;
- c) les actions pour mettre en œuvre les solutions;
- d) les informations d'appui nécessaires pour activer (y compris les critères d'activation), mettre en œuvre, coordonner et communiquer les actions de l'équipe;
- e) les interdépendances internes et externes;
- f) les exigences de ressources;
- g) les exigences de compte rendu;
- h) un processus de sortie.

Chaque plan doit être utilisable et disponible au moment et à l'endroit auxquels il est requis.

8.4.5 Rétablissement

L'organisme doit disposer de processus documentés pour restaurer et revenir à ses activités métier à partir des mesures temporaires adoptées pendant et après une perturbation.

8.5 Programme d'exercices

L'organisme doit mettre en œuvre et maintenir un programme d'exercices et de tests afin de valider dans le temps l'efficacité de ses stratégies et solutions de continuité d'activité.

L'organisme doit mener des exercices et des tests qui:

- a) sont cohérents avec ses objectifs de continuité d'activité;
- b) sont basés sur des scénarios appropriés qui sont bien planifiés avec des buts et des objectifs clairement définis;
- c) développent le travail d'équipe, les compétences, la confiance et les connaissances des personnes qui ont des rôles à jouer en lien avec les perturbations;
- d) cumulés au fil du temps, valident ses stratégies et solutions de continuité d'activité;
- e) permettent de produire des rapports post-exercices formalisés contenant les résultats, les recommandations et les actions pour mettre en œuvre des améliorations;
- f) sont passés en revue dans le contexte de l'effort d'amélioration continue;
- g) sont menés à des intervalles planifiés et lorsque des changements significatifs interviennent au sein de l'organisme ou dans le contexte dans lequel il opère.

L'organisme doit agir en fonction des résultats de ses exercices et tests pour mettre en œuvre des modifications et améliorations.

8.6 Évaluation de la documentation et des capacités de continuité d'activité

L'organisme doit:

- a) évaluer l'adaptation, l'adéquation et l'efficacité de son bilan d'impact sur l'activité, son appréciation des risques, ses stratégies, ses solutions, ses plans et ses procédures;
- b) réaliser ses évaluations par le biais de revues, d'analyses, d'exercices, de tests, de rapports post-incident et d'évaluations des performances;
- c) soumettre à évaluation les capacités de continuité d'activité des partenaires et fournisseurs appropriés;
- d) évaluer la conformité aux exigences réglementaires et juridiques applicables, aux meilleures pratiques de son secteur ainsi que la conformité à sa propre politique de continuité d'activité et aux objectifs associés;
- e) mettre à jour la documentation et les procédures en temps opportun.

Ces évaluations doivent être réalisées à des intervalles planifiés, après un incident ou une activation, et lorsque des changements significatifs interviennent.

9 Évaluation de la performance

9.1 Surveillance, mesure, analyse et évaluation

L'organisme doit déterminer:

- a) ce qu'il est nécessaire de surveiller et mesurer;
- b) les méthodes de surveillance, de mesure, d'analyse et d'évaluation, selon les cas, pour assurer la validité des résultats;
- c) quand et par qui la surveillance et le mesure doivent être effectués;
- d) quand et par qui les résultats de la surveillance et du mesure doivent être analysés et évalués.

L'organisme doit conserver des informations documentées appropriées comme preuves des résultats.

L'organisme doit évaluer la performance et l'efficacité du SMCA.

9.2 Audit interne

9.2.1 Généralités

L'organisme doit réaliser des audits internes à des intervalles planifiés afin de fournir des informations permettant de déterminer si le SMCA:

- a) est conforme:
 - 1) aux exigences propres de l'organisme concernant son SMCA;
 - 2) aux exigences du présent document;
- b) est efficacement mis en œuvre et maintenu.

9.2.2 Programme(s) d'audit

L'organisme doit:

- a) planifier, établir, mettre en œuvre et maintenir un programme d'audit, couvrant notamment la fréquence, les méthodes, les responsabilités, les exigences de planification et le compte rendu. Le programme d'audit doit tenir compte de l'importance des processus concernés et des résultats des audits précédents;
- b) définir les critères d'audit et le périmètre de chaque audit;
- c) sélectionner des auditeurs et réaliser des audits pour assurer l'objectivité et l'impartialité du processus d'audit;
- d) s'assurer qu'il est rendu compte des résultats des audits aux managers pertinents;
- e) conserver des informations documentées comme preuves de la mise en œuvre du ou des programmes d'audit et des résultats d'audit;
- f) s'assurer que toutes les actions correctives nécessaires sont prises sans délai indu pour éliminer les non-conformités détectées ainsi que leurs causes;
- g) s'assurer que les actions de suivi incluent la vérification des actions entreprises et le compte rendu des résultats de cette vérification.

9.3 Revue de direction

9.3.1 Généralités

La Direction générale doit passer en revue le SMCA de l'organisme, à des intervalles planifiés, afin de s'assurer qu'il est toujours adapté, adéquat et efficace.

9.3.2 Éléments d'entrée de la revue de direction

La revue de direction doit prendre en considération:

- a) l'état d'avancement des actions décidées lors des revues de direction précédentes;
- b) les modifications des questions externes et internes pertinentes pour le SMCA;
- c) les informations sur les performances du SMCA, y compris les tendances concernant:
 - 1) les non-conformités et les actions correctives;
 - 2) les résultats de l'évaluation de la surveillance et du mesurage;
 - 3) les résultats des audits;
- d) les retours d'information des parties intéressées;
- e) le besoin d'apporter des modifications au SMCA, y compris en ce qui concerne la politique et les objectifs;
- f) les procédures et les ressources qui pourraient être utilisées dans l'organisme pour améliorer la performance et l'efficacité du SMCA;
- g) les informations issues du bilan d'impact sur l'activité et de l'appréciation du risque;
- h) les éléments de sortie de l'évaluation de la documentation et des capacités de continuité d'activité (voir [8.6](#));
- i) les risques ou les questions qui n'ont pas été traités de manière appropriée lors d'une précédente appréciation du risque;
- j) les leçons tirées et les actions découlant d'incidents évités de justesse et de perturbations;
- k) les opportunités pour l'amélioration continue.

9.3.3 Éléments de sortie de la revue de direction

9.3.3.1 Les éléments de sortie de la revue de direction doivent inclure les décisions relatives aux opportunités d'amélioration continue et à tout besoin d'apporter des modifications au SMCA pour améliorer son efficacité et son efficacité, y compris les éléments suivants:

- a) les variations apportées au domaine d'application du SMCA;
- b) la mise à jour du bilan d'impact sur l'activité, de l'appréciation du risque, des stratégies et solutions de continuité d'activité et des plans de continuité d'activité;
- c) la modification des procédures et des moyens de maîtrise pour répondre aux questions internes ou externes qui peuvent impacter le SMCA;
- d) la manière dont l'efficacité des moyens de maîtrise sera mesurée.

9.3.3.2 L'organisme doit conserver des informations documentées comme preuve des résultats des revues de direction. Il doit:

- a) communiquer les résultats de la revue de direction aux parties intéressées pertinentes;
- b) entreprendre l'action appropriée en fonction de ces résultats.

10 Amélioration

10.1 Non-conformité et actions correctives

10.1.1 L'organisation doit déterminer les opportunités d'amélioration et mettre en œuvre les actions nécessaires pour atteindre les résultats attendus de son SMCA.

10.1.2 Lorsqu'une non-conformité se produit, l'organisme doit:

- a) réagir à la non-conformité, et le cas échéant:
 - 1) agir pour la maîtriser et la corriger;
 - 2) faire face aux conséquences;
- b) évaluer le besoin d'agir pour éliminer la ou les causes de la non-conformité, de sorte qu'elle ne se reproduise pas ni ne se reproduise ailleurs, en:
 - 1) passant en revue la non-conformité;
 - 2) déterminant les causes de la non-conformité;
 - 3) déterminant si des non-conformités similaires existent ou pourraient potentiellement se produire;
- c) mettre en œuvre toute action nécessaire;
- d) passer en revue l'efficacité de toute action corrective mise en œuvre;
- e) modifier le SMCA si nécessaire.

Les actions correctives doivent être à la mesure des effets des non-conformités rencontrées.

10.1.3 L'organisme doit conserver des informations documentées comme preuves:

- a) de la nature des non-conformités et de toutes les actions menées ultérieurement;
- b) des résultats de toute action corrective.

10.2 Amélioration continue

L'organisme doit continuellement améliorer l'adaptation, l'adéquation et l'efficacité du SMCA sur la base de mesures qualitatives et quantitatives.

L'organisme doit prendre en considération les résultats de l'analyse et de l'évaluation, ainsi que les éléments de sortie de la revue de direction pour déterminer s'il existe des besoins ou des opportunités, en lien avec l'activité ou avec le SMCA, à considérer dans le cadre de l'amélioration continue.

NOTE L'organisme peut utiliser les processus du SMCA tels que le leadership, la planification et l'évaluation de la performance, afin d'aboutir à une amélioration.

Bibliographie

- [1] ISO 9001, *Systèmes de management de la qualité — Exigences*
- [2] ISO 14001, *Systèmes de management environnemental — Exigences et lignes directrices pour son utilisation*
- [3] ISO 19011, *Lignes directrices pour l'audit des systèmes de management*
- [4] ISO/IEC/TS 17021-6, *Évaluation de la conformité — Exigences pour les organismes procédant à l'audit et à la certification des systèmes de management — Partie 6: Exigences de compétence pour l'audit et la certification des systèmes de management de la continuité d'activité*
- [5] ISO/IEC 20000-1, *Technologies de l'information — Gestion des services — Partie 1: Exigences du système de management des services*
- [6] ISO 22313, *Sécurité sociétale — Systèmes de management de la continuité d'activité — Lignes directrices*
- [7] ISO 22316, *Sécurité et résilience — Résilience organisationnelle — Principes et attributs*
- [8] ISO/TS 22317, *Sécurité sociétale — Systèmes de management de la continuité d'activité — Lignes directrices pour l'analyse d'impact sur l'activité*
- [9] ISO/TS 22318, *Sécurité sociétale — Systèmes de management de la continuité en affaires — Lignes directrices pour la continuité de la chaîne d'approvisionnement*
- [10] ISO/TS 22330, *Sécurité et résilience — Systèmes de gestion de la poursuite des activités — Lignes directrices concernant les aspects humains de la poursuite des activités*
- [11] ISO/TS 22331, *Sécurité et résilience — Systèmes de management de la continuité des activités — Lignes directrices relatives à la stratégie de continuité d'activité*
- [12] ISO/IEC 27001, *Technologies de l'information — Techniques de sécurité — Systèmes de management de la sécurité de l'information — Exigences*
- [13] ISO/IEC 27031, *Technologies de l'information — Techniques de sécurité — Lignes directrices pour la préparation des technologies de la communication et de l'information pour la continuité d'activité*
- [14] ISO 28000, *Spécifications relatives aux systèmes de management de la sûreté de la chaîne d'approvisionnement*
- [15] ISO 31000, *Management du risque — Lignes directrices*
- [16] IEC 31010, *Management du risque — Techniques d'appréciation du risque*
- [17] Guide ISO 73, *Management du risque — Vocabulaire*

